



ASSESSMENT COVERSHEET

Attach this coversheet as the cover of your submission. All sections must be completed.

Section A: Submission Details

Programme : Bachelor Of Information Technology (Hons) In Computer System Security
Course Code & Name : IKB21403 - VULNERABILITY ANALYSIS
Course Lecturer(s) : Nor Adani Kamal Mohamad Nasir
Submission Title : LAB 1 (FOUNDATION)
Deadline : Day 7 Month 06 Year 2026 Time 11.59pm
Penalties :

- 5% will be deducted per day to a maximum of four (4) working days, after which the submission will **not** be accepted.
- Plagiarised work is an Academic Offence in University Rules & Regulations and will be penalised accordingly.

Section B: Academic Integrity

Tick (✓) each box below if you agree:

- | | |
|-------------------------------------|--|
| ☒ | I have read and understood the UniKL's policy on Plagiarism in University Rules & Regulations. |
| ☒ | This submission is my own, unless indicated with proper referencing. |
| ☒ | This submission has not been previously submitted or published. |
| ☒ | This submission follows the requirements stated in the course. |

Section C: Submission Receipt

(must be filled in manually)

Office Receipt of Submission

Date & Time of Submission (stamp)	Student Name(s)	Student ID(s)
	1 HAZIQ DANIAL BIN NOR AZAN	52215225213

Contents

1. Executive Summary	3
1.1 Overall Risk Level	3
1.2 Biggest Concern	3
1.3 Key Strengths and Weaknesses	4
2. Scope & Methodology	5
2.1 Assessment Details.....	5
2.2 Scope Exclusions.....	5
2.3 Methodology	6
3. Findings Summary	7
3.1 Vulnerability Count by Severity	7
4. Detailed Findings	8
Finding F-01: Canonical Ubuntu Linux End-of-Life (Critical)	8
Finding F-02: VNC Server Weak Password (Critical).....	9
Finding F-03: SSL Version 2 and 3 Protocol Detection (Critical).....	10
Finding F-04: Bind Shell Backdoor Detection (Critical)	11
Finding F-05: Samba Badlock Vulnerability (High).....	12
5. Remediation & Recommendations	13
5.1 Key Learnings	13
6. Conclusion	14

1. Executive Summary

This report presents the findings of a host-based vulnerability assessment conducted against a Metasploitable2 virtual machine (IP: 192.168.56.106). The assessment was performed using Nessus Essentials as part of Lab 1 (Foundation) for the Vulnerability Analysis course. The objective of this assessment is to identify, classify, and prioritise vulnerabilities without exploiting them.

1.1 Overall Risk Level

Category	Details
Overall Risk Level	CRITICAL
Total Vulnerabilities Found	63 vulnerabilities
Critical Findings	4 Critical
High Findings	2 High
Medium Findings	3 Medium
Scan Tool	Nessus Essentials (Basic Network Scan)
Scan Duration	20 minutes (09:27 AM - 09:47 AM)
Target IP	192.168.56.106 (Metasploitable2)

1.2 Biggest Concern

The most critical concern identified during this assessment is the presence of a Bind Shell Backdoor on port 1524 and a VNC service secured with the weak password 'password'. Both vulnerabilities have a CVSS score of 9.8-10.0 and can allow an unauthenticated remote attacker to gain full system-level access to the target without any special tools or skills. Combined with the fact that the operating system (Ubuntu 8.04) has reached End-of-Life and no longer receives security patches, the overall attack surface of this host is extremely high and poses a critical risk to any network it is connected to.

1.3 Key Strengths and Weaknesses

Key Weaknesses identified:

- Operating system has reached End-of-Life (Ubuntu 8.04) with no security patch support
- VNC service accessible with a trivially weak password ('password')
- Bind Shell Backdoor present, allowing unauthenticated remote shell access
- SSL version 2 and 3 enabled, exposing encrypted communications to downgrade attacks
- Samba service vulnerable to the Badlock vulnerability (CVE-2016-2118)

2. Scope & Methodology

2.1 Assessment Details

Field	Details
Assessment Type	Host-Based Vulnerability Assessment (Unauthenticated)
Target IP / Host	192.168.56.106 (Metasploitable2 / DVWA)
Scan Tool	Nessus Essentials v10.x
Scan Template	Basic Network Scan
Scanner	Local Scanner (Kali Linux)
Starting Date	23 May 2026
End Date	23 May 2026
Duration	20 minutes
Network	Host-Only Adapter (VirtualBox)

2.2 Scope Exclusions

The following were excluded from this assessment:

- No exploitation of discovered vulnerabilities was performed
- No Denial of Service (DoS) attacks were conducted
- No social engineering attempts were made
- Assessment limited to host 192.168.56.106 only

2.3 Methodology

The assessment followed a standard vulnerability scanning methodology based on NIST SP 800-115 and consisted of the following phases:

- Network Confirmation: Verified connectivity between Kali Linux (attacker) and Metasploitable2 (target) using ICMP ping
- Scan Configuration: Created a Basic Network Scan in Nessus Essentials targeting IP 192.168.56.106
- Vulnerability Scanning: Executed the scan and waited for completion (approximately 20 minutes)
- Analysis: Sorted results by severity and identified the Top 5 vulnerabilities for detailed review
- Reporting: Documented findings with CVE IDs, CVSS scores, descriptions, impacts, and remediation recommendations

3. Findings Summary

The following table provides a summary of the Top 5 vulnerabilities identified during the assessment, sorted by severity:

ID	Vulnerability Name	CVE	CVSS	Severity	Port/Service
F-01	Canonical Ubuntu Linux SEoL (8.04.x)	N/A	10.0	CRITICAL	General
F-02	VNC Server 'password' Password	N/A	10.0	CRITICAL	5900/tcp/vnc
F-03	SSL Version 2 and 3 Protocol Detection	N/A	9.8	CRITICAL	25/tcp/smtp
F-04	Bind Shell Backdoor Detection	N/A	9.8	CRITICAL	1524/tcp
F-05	Samba Badlock Vulnerability	CVE-2016-2118	7.5	HIGH	445/tcp/cifs

3.1 Vulnerability Count by Severity

Severity	Count	Percentage
Critical	4	80%
High	1	20%
Medium	0	0%
Low	0	0%
TOTAL	5	100%

CVSS v2.0 Ratings

Low	0.0-3.9
Medium	4.0-6.9
High	7.0-10.0

CVSS v3.0 Ratings

Low	0.1-3.9
Medium	4.0-6.9
High	7.0-8.9
Critical	9.0-10.0

4. Detailed Findings

Finding F-01: Canonical Ubuntu Linux End-of-Life (Critical)

Vulnerability Name	Canonical Ubuntu Linux SEoL (8.04.x) — Unsupported OS Version
CVE ID	N/A (Plugin ID: Nessus detection)
CVSS Score	10.0 (Critical) — CVSS v2.0
CVSS Vector	CVSS2#AV:N/AC:L/Au:N/C:C/I:C/A:C
Severity	CRITICAL
Affected Port/Service	General (OS-level)
False Positive?	No — Ubuntu 8.04 LTS officially reached End-of-Life on April 9, 2013

Description:

The target system is running Ubuntu Linux 8.04 (Hardy Heron), which has reached its End-of-Life (EOL) and no longer receives security updates or patches from Canonical. This means any newly discovered vulnerabilities in the operating system will remain permanently unpatched, leaving the system exposed to exploitation indefinitely.

Impact:

- No security patches will be provided for any future vulnerabilities
- Existing known vulnerabilities remain permanently exploitable
- Attacker can leverage unpatched OS-level flaws to gain full system compromise
- Risk of data breach, unauthorized access, and complete system takeover

Remediation (Immediate):

- Upgrade the operating system to a currently supported Ubuntu LTS release (e.g., Ubuntu 22.04 or 24.04)
- If upgrade is not immediately possible, isolate the system from production networks
- Apply all available patches before migration

Finding F-02: VNC Server Weak Password (Critical)

Vulnerability Name	VNC Server 'password' Password — Insufficient Authentication
CVE ID	N/A (Plugin ID: 61708)
CVSS Score	10.0 (Critical) — CVSS v2.0
CVSS Vector	CVSS2#AV:N/AC:L/Au:N/C:C/I:C/A:C
Severity	CRITICAL
Affected Port/Service	5900/tcp (VNC)
False Positive?	No — Nessus successfully authenticated using the password 'password'

Description:

The VNC (Virtual Network Computing) server running on port 5900 is configured with an extremely weak password — 'password'. Nessus was able to successfully log in using this credential. VNC provides full graphical desktop access to the remote system, meaning any attacker who discovers this service can immediately take complete control of the system without any additional exploitation required.

Impact:

- Attacker gains full graphical desktop control of the target system
- Can execute any commands, install malware, or exfiltrate data
- No technical skill required — trivially exploitable by any attacker
- Can be used as a pivot point to attack other systems on the network

Remediation (Immediate):

- Immediately change the VNC password to a strong, complex password (minimum 16 characters)
- Restrict VNC access using firewall rules — allow only trusted IP addresses
- Consider disabling VNC if remote graphical access is not required
- Implement VPN requirement before allowing VNC connections

Finding F-03: SSL Version 2 and 3 Protocol Detection (Critical)

Vulnerability Name	SSL Version 2 and 3 Protocol Detection — Deprecated Encryption
CVE ID	N/A (Plugin ID: 20007)
CVSS Score	9.8 (Critical) — CVSS v3.0
CVSS Vector	CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Severity	CRITICAL
Affected Port/Service	25/tcp (SMTP), 5432/tcp (PostgreSQL)
False Positive?	No — SSLv2 and SSLv3 were confirmed to be enabled on the target

Description:

The target system accepts connections using SSL version 2.0 and SSL version 3.0, both of which are deprecated and cryptographically broken protocols. SSLv2 has been known to be insecure since the late 1990s, and SSLv3 is vulnerable to the POODLE attack (CVE-2014-3566). These protocols support weak cipher suites and insecure renegotiation, allowing attackers to perform man-in-the-middle attacks and decrypt encrypted communications.

Impact:

- Attacker can perform man-in-the-middle (MITM) attacks to intercept encrypted traffic
- Sensitive data transmitted over SMTP or PostgreSQL can be decrypted
- Credentials, database contents, and email data may be exposed
- Enables downgrade attacks, forcing clients to use weaker encryption

Remediation (Short-term):

- Disable SSLv2 and SSLv3 on all services (SMTP, PostgreSQL)
- Enable TLS 1.2 or TLS 1.3 as the minimum accepted protocol version
- Update cipher suites to exclude weak/export-grade ciphers
- Reference: NIST SP 800-52 Rev. 2 for TLS configuration guidelines

Finding F-04: Bind Shell Backdoor Detection (Critical)

Vulnerability Name	Bind Shell Backdoor Detection — Unauthenticated Remote Shell
CVE ID	N/A (Plugin ID: 51988)
CVSS Score	9.8 (Critical) — CVSS v3.0
CVSS Vector	CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Severity	CRITICAL
Affected Port/Service	1524/tcp (wild_shell)
False Positive?	No — Nessus executed the 'id' command and received 'uid=0(root) gid=0(root) groups=0(root)'

Description:

A bind shell backdoor is listening on port 1524. This is a pre-installed backdoor in Metasploitable2 that provides a root shell without any authentication required. Nessus confirmed this by connecting to the port and executing the 'id' command, which returned root-level access (uid=0). Any attacker who can reach this port has immediate, full, unrestricted root access to the entire system.

Impact:

- Immediate root-level shell access with no authentication required
- Complete system compromise — attacker can do anything as root
- Can read, modify, or delete any file on the system
- Can install additional malware or use system as a launching point for further attacks
- Highest possible impact on Confidentiality, Integrity, and Availability
-

Remediation (Immediate — HIGHEST PRIORITY):

- Immediately block port 1524 at the firewall level
- Identify and terminate the backdoor process: use 'netstat -tlnp | grep 1524' to find the process
- Remove or kill the backdoor service and investigate how it was installed
- Conduct a full forensic investigation to determine if the system has been compromised
- Consider rebuilding the system from a clean image

Finding F-05: Samba Badlock Vulnerability (High)

Vulnerability Name	Samba Badlock Vulnerability — Authentication Downgrade Attack
CVE ID	CVE-2016-2118
CVSS Score	7.5 (High) — CVSS v3.0
CVSS Vector	CVSS:3.0/AV:N/AC:H/PR:N/UI:R/S:U/C:H/I:H/A:H
Severity	HIGH
Affected Port/Service	445/tcp (CIFS/SMB)
False Positive?	No — Nessus confirmed the Samba Badlock patch has not been applied

Description:

The version of Samba running on this host is affected by the Badlock vulnerability (CVE-2016-2118). This flaw exists in the Security Account Manager (SAM) and Local Security Authority (Domain Policy) protocols due to improper authentication level negotiation over RPC channels. A man-in-the-middle attacker who intercepts traffic between a client and a Samba server can force a downgrade of the authentication level, allowing them to execute arbitrary Samba network calls in the context of the intercepted user.

Impact:

- Man-in-the-middle attacker can intercept and manipulate SMB/CIFS traffic
- Can view or modify sensitive security data in the SAM database
- Can disable critical services or modify Active Directory-equivalent configurations
- Potential for privilege escalation if administrative shares are accessed

Remediation (Short-term):

- Upgrade Samba to version 4.2.11 / 4.3.8 / 4.4.2 or later (patched versions)
- If upgrade is not immediately possible, restrict SMB access via firewall
- Disable SMB if file sharing is not required on this host
- Reference: <https://www.samba.org/samba/security/CVE-2016-2118.html>

5. Remediation & Recommendations

The following table summarises the recommended remediation actions, prioritised by urgency:

Finding	Priority	Remediation Action
F-04: Bind Shell Backdoor	IMMEDIATE	Block port 1524, terminate backdoor process, investigate system compromise
F-02: VNC Weak Password	IMMEDIATE	Change VNC password immediately, restrict access via firewall rules
F-01: Ubuntu EOL	SHORT-TERM	Upgrade OS to supported Ubuntu LTS (22.04 or 24.04)
F-03: SSL v2/v3	SHORT-TERM	Disable SSLv2/v3, enforce TLS 1.2 minimum on all services
F-05: Samba Badlock	SHORT-TERM	Upgrade Samba to patched version (4.2.11+) or disable if not needed

5.1 Key Learnings

Finding vs Real Risk:

While the full Nessus scan identified 63 vulnerabilities, this report focuses on the Top 5 most critical findings. Not all 63 findings represent immediate real-world risk — some may be informational findings, false positives, or low-severity issues that require additional context to assess actual exploitability.

False Positives:

Vulnerability scanners such as Nessus detect vulnerabilities primarily by checking software version numbers against known vulnerability databases. In some cases, a system may have applied a patch without updating the version string, causing the scanner to report a vulnerability that has already been remediated. All findings in this report were assessed as true positives based on available evidence.

6. Conclusion

This vulnerability assessment of Metasploitable2 (192.168.56.106) identified 63 total vulnerabilities, with 5 selected as the most critical for detailed analysis. The overall risk posture of the target host is CRITICAL, primarily due to the presence of an unauthenticated bind shell backdoor, a VNC service with a trivially weak password, and an End-of-Life operating system that will never receive security patches.

It is strongly recommended that the identified critical and high severity vulnerabilities be remediated immediately, starting with the Bind Shell Backdoor (F-04) and the VNC weak password (F-02), both of which can be exploited by any unauthenticated attacker with network access.

Note: Metasploitable2 is an intentionally vulnerable virtual machine designed for security training purposes. It should never be deployed in a production environment or connected to an untrusted network.